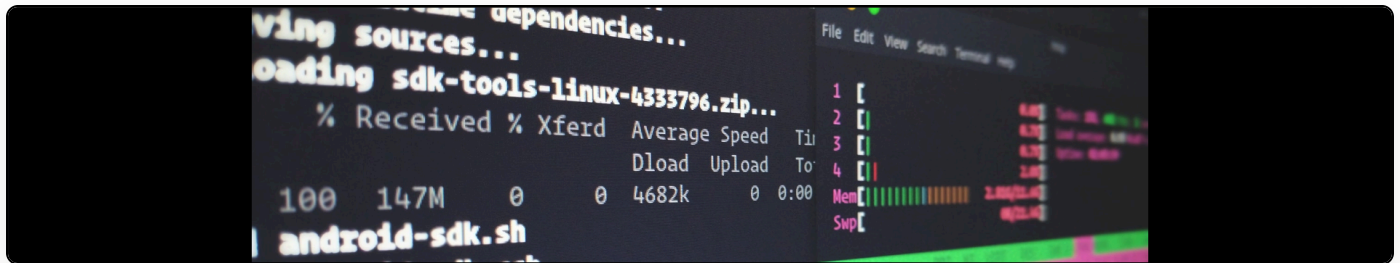


(C)SRF one-time token bypass using AJAX and XSS

Cite as: Martin Paul Eve, "(C)SRF one-time token bypass using AJAX and XSS", *eve.gd: Martin Paul Eve*, May 24, 2007, <https://doi.org/10.59348/xk536-c7k02>.



This morning I knocked up some proof of concept code to illustrate the retrieval of one-time authentication tokens. The situation in which this is handy is when a site follows best practices and implements a one-time authentication token, but is vulnerable to a XSS attack. A one-time authentication token is a hidden value implanted into either a link or form. For example, Digg's one-time token looks like this:

```
<a href="javascript:dig(0,2075898,'3ba1562c0c94a28b862f8c58fa3b44d3')">digg it</a>
```

So, performing the actions in the "dig" function without the correct token (which is issued on a per-session basis) has no effect and will probably trigger a security alert. However, imagine if Digg was found to be vulnerable to a XSS hole - it would be possible to read the token by submitting an AJAX request and then parsing the response. Here is a snippet from the code that does just that:

```
var match = regexMatch('javascript:dig\\(\\d,\\d+,([^\"]+)',response);
```

This example is not particularly sophisticated, but it illustrates that XSS attacks are NOT protected against by implementing one time-tokens and that CSRF attacks are still entirely possible if a XSS hole is found in the site, tokens or not.